CEEPEW Systems Architecture & Security Audit

PROJECT META

Project: Cryptographic End-to-End Peer-to-peer Encrypted Wireless Communicator

Firmware Version: `1.0.0`

Platform: `ESP-IDF 6.0.2` / `FreeRTOS`

Author: Rishi Misra (VIT Vellore / `BACSE324` Embedded Systems Architecture)

EXECUTIVE READOUT

7-Layer
Cryptographic Stack

Dual-Core
Task Isolation

0 Bytes
Heap Allocation in Session Layer

STATUS: ASSEMBLED PROTOTYPE END-TO-END VERIFIED ON PHYSICAL HARDWARE

Gemini Notebook

Physical Architecture & Hardware Component Matrix

MICROCONTROLLER

ESP32 DevKit v1 (Xtensa LX6 dual-core).

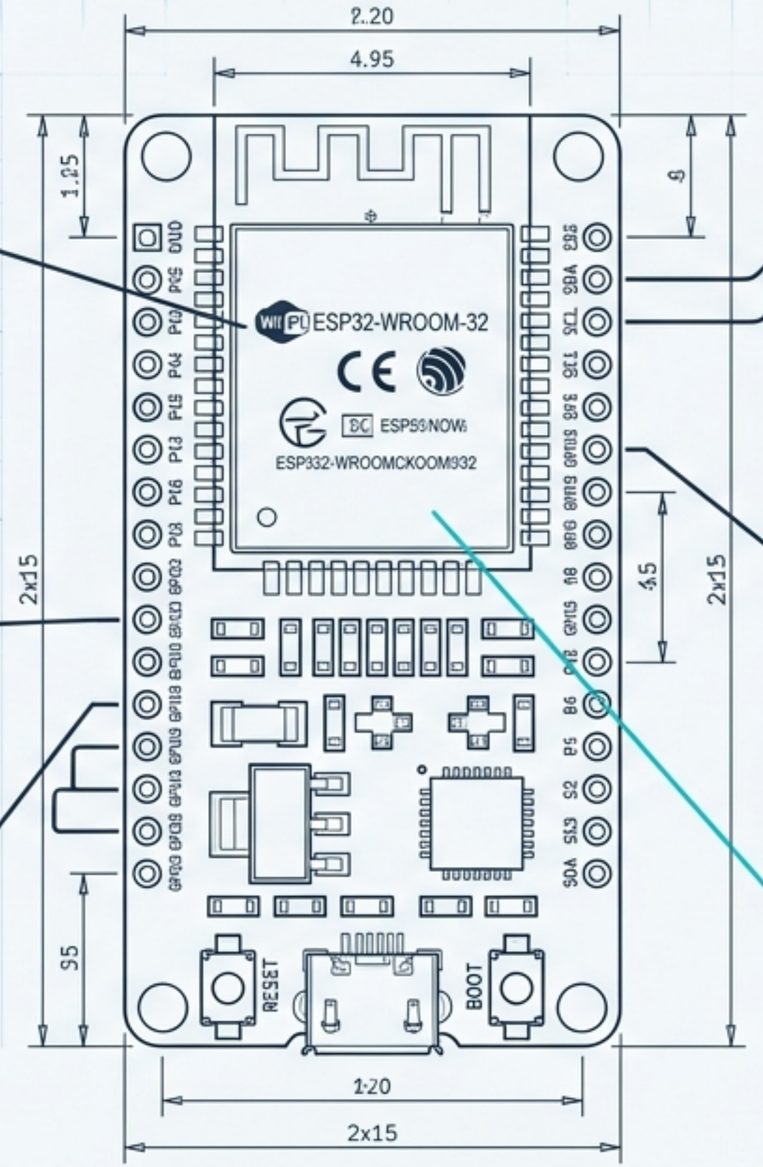
Correction Notice: Physical flash confirmed at 4 MB via ESPTOOLPY_FLASHSIZE_4MB=y (supercedes outdated 2 MB documentation).

ANALOG INPUT

Rotary Potentiometer (GPIO33, ADC1 CH5, 12-bit, 8-sample avg)

VISUAL OUTPUT

Common-cathode RGB LED (R=15, G=18, B=23)



DISPLAY OUTPUT

SSD1306 128x64 OLED (I2C at 800 kHz, SDA=26, SCL=27).

Explicitly defaults to SSD1306; SH1106 initialization causes blank screen.

DIGITAL INPUT

Click Button (GPIO19, 25ms debounce) & Push-Lock DIAG Switch (GPIO5).

RADIO LAYER

Internal BLE (Bluedroid) for pairing, WiFi (802.11 b/g/n) for ESP-NOW

Gemini Notebook

Dual-Core Execution and Static Memory Allocation

Core 0

task_ui_run()
(10 KB Stack)

Handles OLED rendering at ~60Hz, input debounce, and 20+ UI states.

IPC

g_ui_event_queue
(8 slots, 28B each) passing messages from Core 1 to Core 0, protected by **g_crypto_mutex** and **g_ui_ctx_lock**.

Core 1

task_session_run()
(16 KB Stack)

Handles Session FSM, Cryptography, TX/RX Pipelines, and Transport callbacks.

48 KB Static Region Bump Allocator

All application session and crypto data uses this g_region pool.
Zero malloc()/free() calls exist in the crypto or session pipelines.

Note: FreeRTOS task creation and BLE initialization utilize system heap, which is strictly released post-pairing.

Gemini Notebook

The Sequential 3-Phase Communication Lifecycle

SPEC

Phase 1: Discovery

Devices advertise `16B_SHA256_commitment` every 100ms.

Lower MAC address automatically assumes the Initiator role.

SPEC

Phase 2: Pairing

BLE GATT identity exchange (`Ascon-128` encrypted).

Generates a 4-character deterministic display PIN.

Users verify and click to confirm (providing ~20 bits of brute-force resistance in a 45s window).

TEAR-DOWN THRESHOLD

SPEC

Phase 3: Session

WiFi STA initialized.

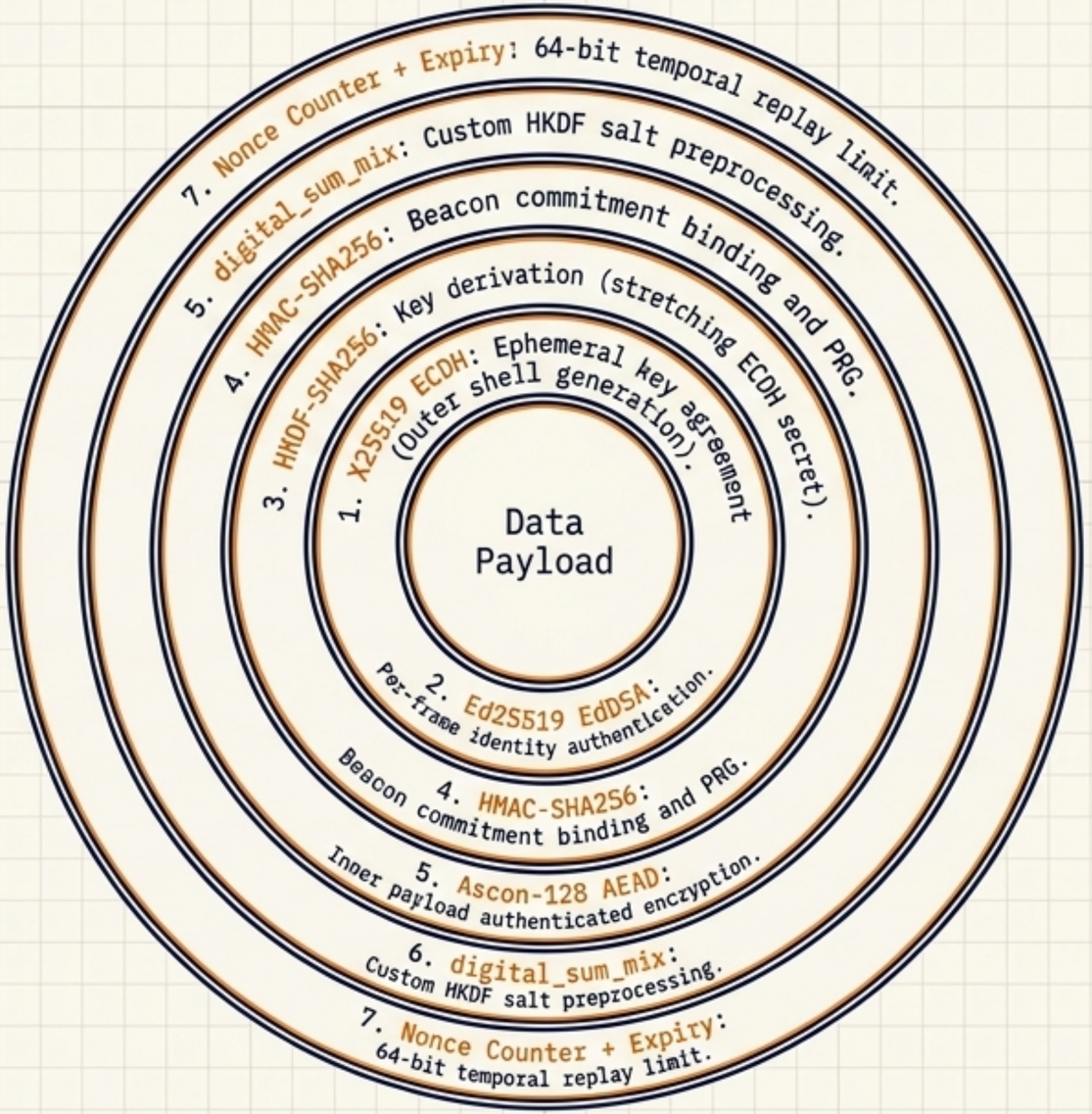
ESP-NOW tunnel established on Channel 1 using Phase 2 keys.

Diagnostic Note:
Both devices exchange a `HANDOFF_READY` beacon. `esp_bluedroid_deinit()` fires.

BLE and ESP-NOW operate strictly sequentially. They do not run concurrently, preventing radio hardware contention.

Gemini Notebook

The Seven-Layer Authenticated Security Architecture



The eFuse Decision.
eFuse HMAC device binding exists in the source tree but is inactive by explicit design decision for standard DevKit hardware.

The system enforces exactly seven active layers.

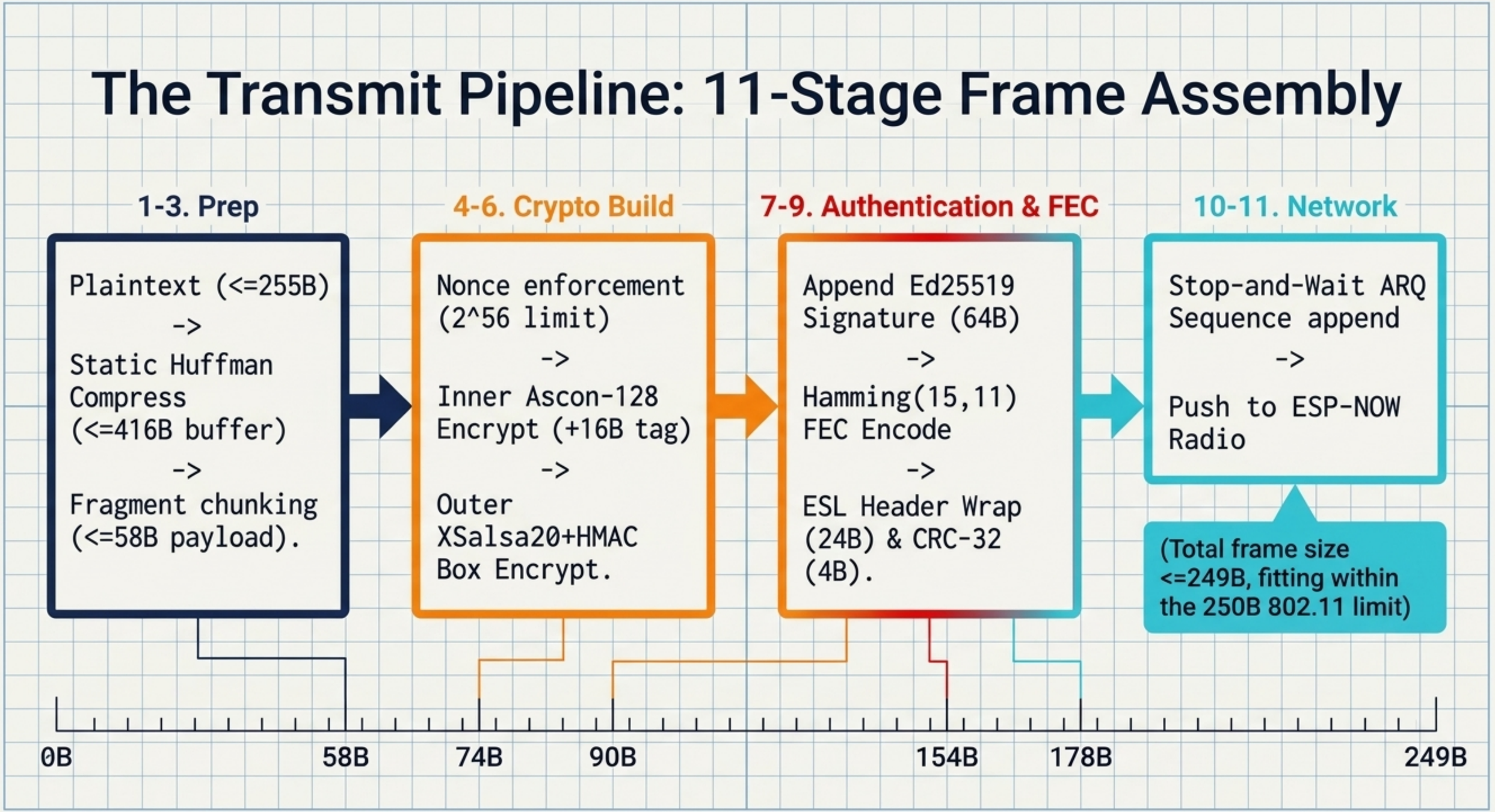
Gemini Notebook

Cryptographic Primitive Selection Matrix

Primitive	Standard	Source Library	Security Role
Ascon-128 AEAD	NIST SP 800-232	Standalone C	Inner payload confidentiality & tag authentication.
X25519 ECDH	RFC 7748	Standalone C	Shared secret establishment with low-order key rejection.
Ed25519 EdDSA	RFC 8032	Standalone C	Per-frame non-repudiation binding to device identity.
HKDF-SHA256	RFC 5869	crypto_hkdf.c	Derives ascon_key, box_seed, PMK, and LMK using domain labels.
Outer Box (Nested AEAD)	XSalsa20 + HMAC-SHA256	Custom wrap	Wraps Ascon ciphertext. Note: Non-standard layered construction explicitly chosen for independent key defense-in-depth.
SHA-256 & HMAC	FIPS 180-4	mbedTLS (PSA)	Used for commitments, HKDF underlying hash, and channel hop PRG.

Gemini Notebook

The Transmit Pipeline: 11-Stage Frame Assembly



Gemini Notebook

The Receive Pipeline: 10-Stage Decryption Gauntlet

Stage 1-2 — Spec

DoS Cookie Guard (drops if queue > 6 without valid HMAC)
-> MAC Lock (ceepew_ct_equal constant-time peer verification).

Stage 3-4 — Transport/Radio

ESL CRC-32 Validate -> Hamming(15,11) FEC Decode.

NACK

Fails here trigger ARQ NACKs.

Stage 5-6

Timestamp Check (+/-45s window)
-> WireGuard Replay Bitmap (64-bit sliding window).

SILENT DROP

Stage 7-9 — Cryptography

Outer Box Decrypt (HMAC Verify)
-> Ascon-128 Decrypt & Tag Verify -> Ed25519 Signature Verify.

SILENT DROP

Stage 10

Defragment -> Huffman Decompress -> Deliver to g_ui_event_queue.

Gemini Notebook

The ESP-NOW Reliability Stack

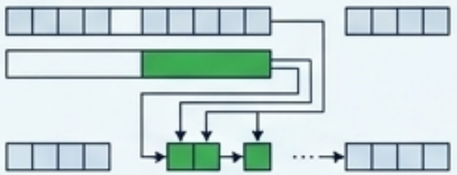
Stop-and-Wait ARQ

```
CEEPEW_ARQ_EFFECTIVE_MAX_RETRIES = 5
```

Code inspection confirms 5 effective transmission attempts (spanning the 5-second hop boundary), correcting earlier documentation claiming 3. Backoff is exponential (100ms, 200ms, 400ms) with +/-10% TRNG jitter.

Hamming(15,11) Forward Error Correction

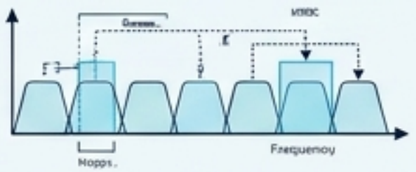
36.4% encoding overhead. Single-bit O(1) correction via syndrome table.



Security Add-on:
Applies a session-keyed Fisher-Yates bit permutation per codeword to randomize burst-error exposure.

HMAC-PRG Channel Hopping

```
9 Base Channels (1,6,11,3,8,2,7,9,4).
```



Hop interval strictly enforced at 5,000ms. Frequency diversity forces passive eavesdroppers to predict the HMAC-PRF output.

Gemini Notebook

Engineered Solutions to Embedded Constraints

Constraint	Engineered Solution
The Collision Problem Simultaneous bidirectional encryption causes nonce reuse.	Transport/Radio **Parity Invariant.** **Initiator uses strictly even nonces** (`0, 2, 4`); Responder uses **strictly odd** (`1, 3, 5`). Sequences are mathematically disjoint.
The Clock Drift Problem ESP-IDF raw uptime causes clock skew across devices, failing temporal replay checks.	Cryptography Memory/OS **Window Widening.** Timestamp slack expanded from +/-15s to +/-45s, relying on the 64-bit **WireGuard sequential bitmap** to catch sub-window replays.
The RF Interference Problem Heavy 2.4GHz traffic blocks Phase 2 GATT identity exchange.	Threat/Validation logic Transport/Radio **Identity-Degraded Mode.** Failsafe state allowing session to proceed without Ed25519 verification, requiring explicit physical button consent and rendering a persistent 'UNVERIFIED IDENTITY' UI banner.

Gemini Notebook

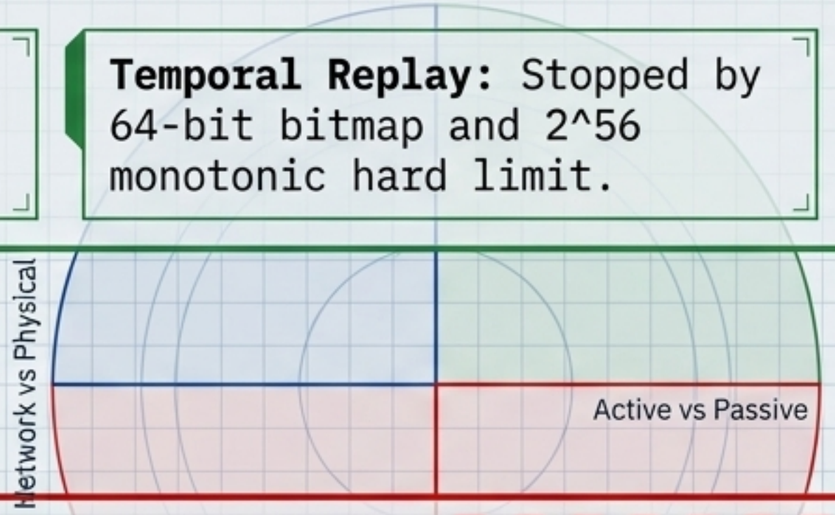
Threat Model Scope and System Limitations

Defended Threats

Passive Eavesdropping: Stopped by independent dual-layer AEAD.

Temporal Replay: Stopped by 64-bit bitmap and 2^56 monotonic hard limit.

Post-Pairing MITM: Stopped by Ed25519 binding to encrypted frames.



Accepted Limitations

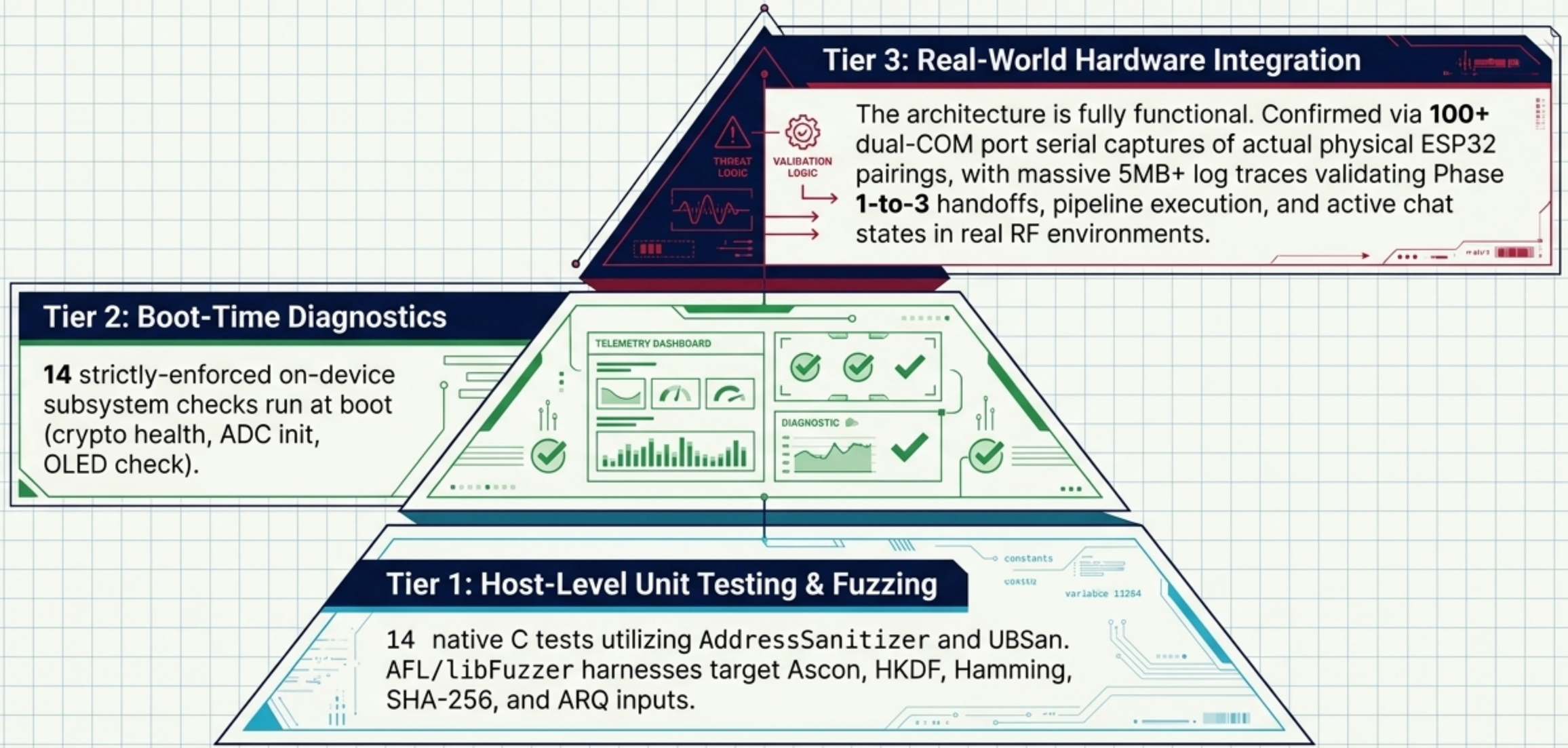
Physical Hardware Extraction: Keys remain in SRAM; no secure enclave. Device identity is soft (MAC-based) without eFuse binding.

Side-Channel Leakage: ceepew_ct_equal and secure_zero protect core comparisons, but the underlying mbedTLS SHA-256 lacks constant-time execution guarantees on LX6.

Pre-Pairing MITM: Solely bounded by a short 45-second window and visual user verification of the ~20-bit entropy 4-character PIN.

Gemini Notebook

Multi-Tier Validation & Hardware Execution Proof



Gemini Notebook